PRESENTING: LOCKSMITH

A TINY TOOL FOR FIXING COMMON AND DANGEROUS ISSUES IN ACTIVE DIRECTORY CERTIFICATE SERVICES

JAKE HILDRETH

SENIOR SECURITY CONSULTANT @ TRIMARC

ABOUT JAKE

- Past
  - 20+ years as all-around “IT person”
- Present
  - Senior Security Consultant at Trimarc
- Forever
  - Husband
  - Dad
  - Blue Teamer

WHAT IS ACTIVE DIRECTORY CERTIFICATE SERVICES (AD CS)?

- Microsoft's implementation of PKI
- Incredibly easy to set up
- Incredibly easy to screw up

THE STATE OF AD CS RESEARCH… AND EXPLOITATION

- Pre-history (BCPO): A wide variety of techniques spread across the internet explaining how to use and abuse AD CS
- Summer 2021: Certified Pre-Owned is released
- April 2022: Mandiant reveals APT29 is using AD CS to compromise high-value targets
- Throughout 2022: Pentesting companies now rely on AD CS vulnerabilities for easy wins

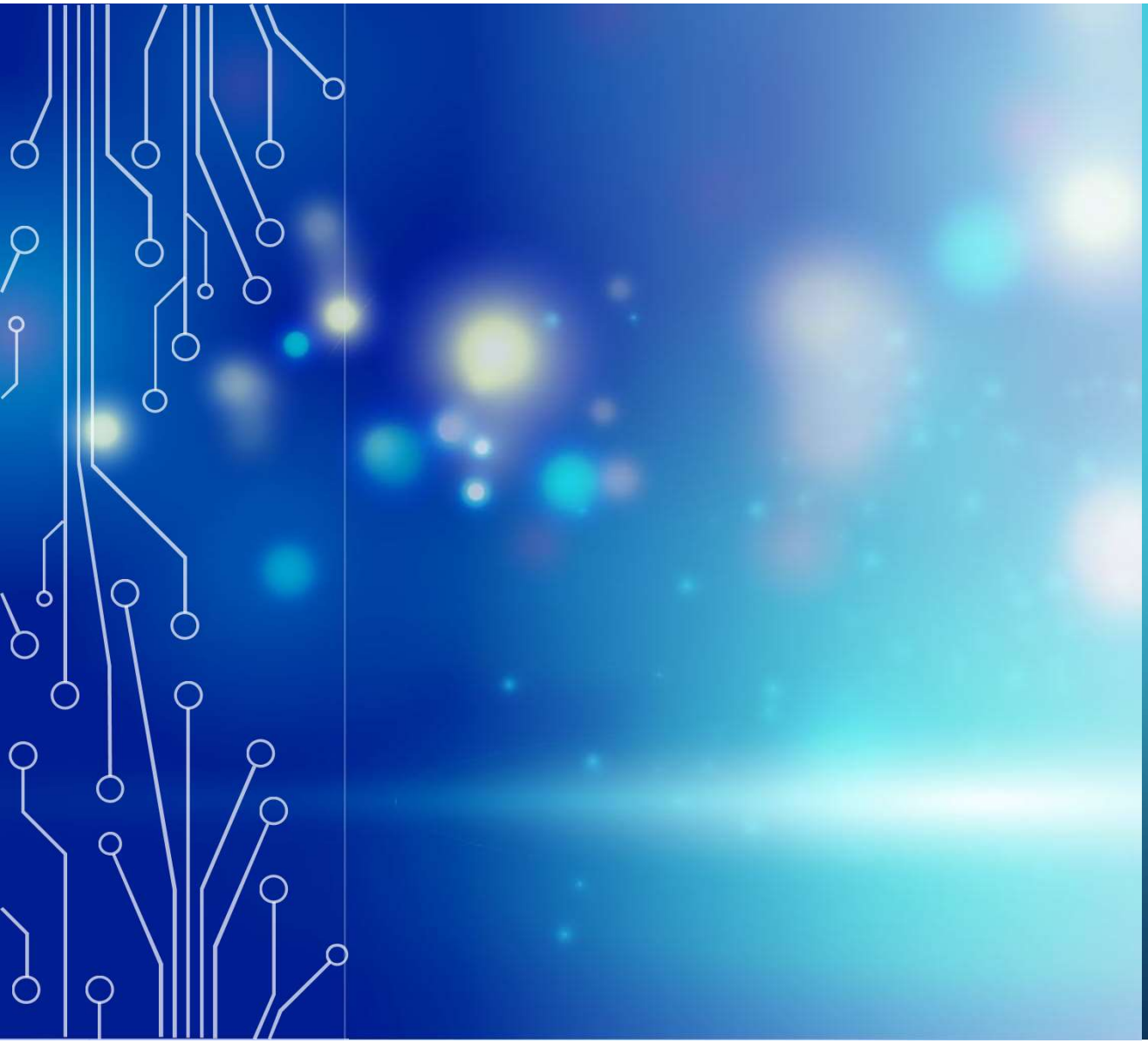


COMMON AD CS ISSUES

- No Auditing
- Overly-permissive Access Controls
- Dangerous Templates
- Dangerous CAs

LOCKSMITH CAN HELP!

- Scan AD CS
- Find Stuff
- Report
- Remediate!



DEMO TIME!

OOOOOOH!

✧･ﾟ:*✧･ﾟ:*SPARKLY*:･ﾟ✧*:･ﾟ✧

TODO

- Text-based User Interface
- Improved Error Handling
- Multi-Forest Support
- Verify Auditing GPOs exist, Alert if not.
- Improved Remediation of overly-permissive ACL issues
- Additional methods to remediate dangerous templates
- Check for elevation before attempting to fix anything

SAY HI!

WWHF Discord: dotdotdotHorse - Trimarc

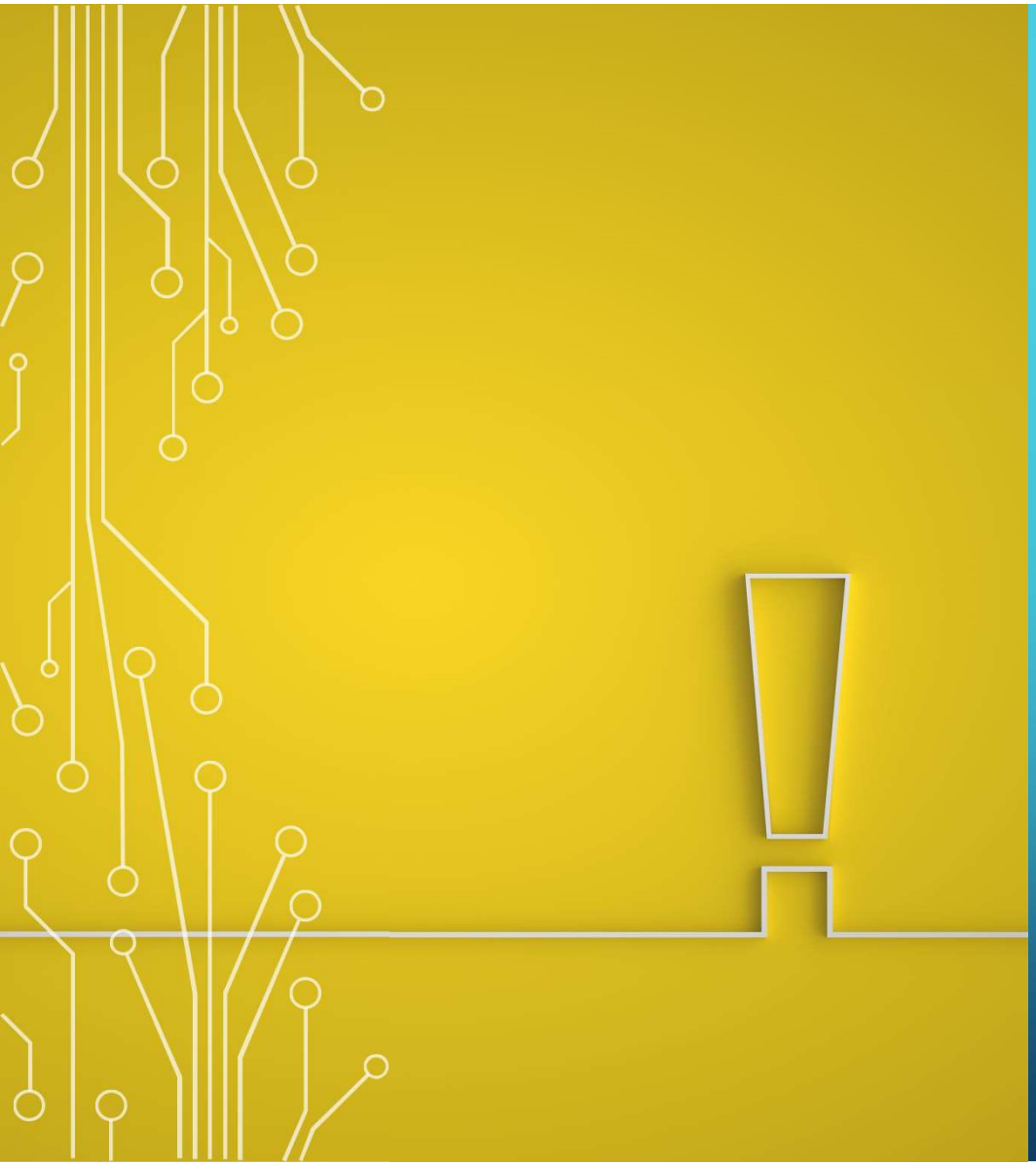
GitHub: github.com/TrimarcJake

Twitter: @dotdotdotHorse

LinkedIn: in/jakehildreth

Email: Absolutely not.

Phone: Never.



THANKS!!

